LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şart: (1) Bileşen var mı: hat SBOM'unda Component X (PLC firmware kütüphanesi) yer alıyor mu? (2) Sürüm 2.4 etkileniyor mu? (3) Açık ulaşılabilir mi: PLC ağdan/uzak erişimden erişilebiliyor mu? Üçü de evet ise bizi etkiler; biri hayırsa risk düşer, yine de kayda alınır.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam: CVSS 9.8 tek başına durdurma nedeni değildir. Önce üç şart ve ulaşılabilirlik değerlendirilir; erişim varsa uzak erişimi keser/izole ederim, yamayı planlı duruşta uygularım. Aktif istismar kanıtı varsa hat önce güvenli duruma alınır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: yama doğrudan üretime değil, test/yedek PLC veya simülasyon ortamında, yedek ve geri dönüş planıyla denenir; sonra planlı duruşta uygulanır ve sonuç doğrulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, etkileyebilir: yama safety'ye dokunuyorsa (firmware, I/O, ağ) validasyon tekrarlanır. Anlamak için sürüm notu ve etki analizi okunur; yama sonrası fonksiyon testi yapılır (E-stop ve ışık perdesi → robot/konveyör durur, tepki süresi ölçülür, safety konfigürasyonu yedekle karşılaştırılır).

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Telafi edici önlem: PLC'yi ağ segmentasyonuyla izole etmek, güvenlik duvarı kuralı, uzak erişimi kapatmak veya VPN + MFA ile sınırlamak, USB/port kilidi, izleme ve anomali tespiti; safety yolunun bağımsız kalması; yama olana kadar riski açık takibe almak.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.